

Table of Contents

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

HIPAA

Un Manual de Cumplimiento y Seguridad Prácticas para Gerentes y Analistas Junior

How health-information privacy, security, breach response, evidence, and oversight work in practice

Alberto (Al) Leiva

Primera edición • Julio 2026

Silencio **Inside:** Regla de Privacidad • Regla de Seguridad • Notificación de Breach • Parte 2 • Manual de administración • Herramientas de código abierto • Laboratorios de analista junior • Preparación de entrevistas Silencio.

Publication and Use Notice

Autor: Alberto (Al) Leiva

Edición: Primera edición, Julio 2026

Propósito: Educación gratuita y práctica para directivos, estudiantes, cambiadores de carrera, analistas juniores, profesionales de la privacidad y profesionales de la ciberseguridad.

Aviso educativo y legal

Este manual proporciona información educativa general. No es asesoramiento jurídico y no reemplaza asesoramiento de abogados calificados, oficiales de privacidad, oficiales de seguridad o profesionales de la información sanitaria. Los derechos de HIPAA dependen de hechos, papel, contratos, normativa y orientación federales actuales, leyes estatales y otras normas de información sanitaria.

Uso ético y autorizado

Utilice herramientas técnicas y ejercicios sólo con autorización escrita y sólo con datos ficticios, sintéticos o adecuadamente desidentificados. Nunca coloque información de pacientes reales en un repositorio público, laboratorio de formación, demostración, cartera o servicio no aprobado. La habilidad técnica no crea permiso.

Prefacio

Una introducción acogedora al trabajo práctico HIPAA.

HIPAA se reduce a menudo a una frase: no comparta la información del paciente. Eso es incompleto. El trabajo real HIPAA incluye entender quién está regulado, qué información está protegida, qué usos y divulgaciones se permiten, cómo funcionan los derechos individuales, cómo se asegura el PHI electrónico, cómo se evalúan los incidentes, y cómo las pruebas demuestran que los controles funcionan realmente.

Los administradores deben asignar responsabilidad, financiar salvaguardias razonables, eliminar obstáculos, revisar el riesgo honestamente y tomar decisiones oportunas. Los analistas juniores apoyan datos y mapeo de sistemas, exámenes de acceso, análisis de riesgos, pruebas de políticas, solicitudes de derechos, archivos asociados de negocios, hechos de incidentes, registros de capacitación y acciones correctivas.

Este manual sigue un enfoque basado en la metodología. Una herramienta de exploración puede identificar una debilidad, pero no puede decidir si todo el análisis de riesgo es preciso y minucioso. Un repositorio de contrato puede almacenar un BAA, pero no puede probar que el vendedor lo siga. Un dashboard puede mostrar estado verde, pero la administración sigue siendo responsable de lo que significa ese estado.

Silencio Lección central: El cumplimiento de HIPAA es un programa de gestión continuo que conecta la privacidad de la información sanitaria, la ciberseguridad, el comportamiento de la fuerza de trabajo, los proveedores, los derechos de los pacientes, la respuesta a incidentes y la evidencia. Silencio.

— *Alberto (Al) Leiva*

Cómo utilizar este manual

Los administradores deben comenzar con los Capítulos 1 a 13 y utilizar el libro de juegos y plantillas como referencias de trabajo.

Los analistas juniores deben estudiar la guía reguladora, evidencia, herramientas, laboratorio ficticio, proyectos de cartera y capítulo de entrevista.

Los lectores técnicos deben conectar cada hallazgo técnico a la ePHI, un riesgo, una salvaguardia, un propietario, pruebas de revisión y corrección.

La privacidad y los equipos legales deben verificar la orientación actual del HHS, el texto del ECFR, las leyes estatales y otras normas especializadas de información sobre salud.

Silencio ** Nota de edición: ** La guía del capítulo visible contiene números de página verificados para esta edición. El campo nativo de Word se puede refrescar después de la edición seleccionando la tabla de actualización, y luego actualizar la tabla completa. Silencio.

Tabla de contenidos

Notificación de publicación y uso [2](#publication-and-use-notice)

Notificación económica y jurídica [2](#educational-and-legal-notice)

Uso electrónico y autorizado [2] (#ethical-and-authorized-use)

Prefacio [3] (#preface)

Cómo utilizar este manual [4](#how-to-use-this-manual)

Tabla de contenidos [4](#table-of-contents)

1. HIPAA Foundations [9](#hipaa-foundations)

1.1 Reglas HIPAA [9](#the-hipaa-rules)

1.2 HIPAA no es una ley general de salud-datos [9](#hipaa-is-not-a-general-health-data-law)

1.3 Punto de control de la ley actual [9](#current-law-checkpoint)

2. Alcance, Roles, PHI y ePHI [10](#scope-roles-phi-and-ephi)

2.1 Entidades cubiertas [10](#covered-entities)

2.2 Asociados comerciales [10](#business-associates)

2.3 PHI y ePHI [10](#phi-and-ephi)

2.4 De-identificación [11](#de-identification)

3. Regla de Privacidad: Usos y Divulgaciones [12](#privacy-rule-uses-and-disclosures)

3.1 Se requiere versus permitido [12](#required-versus-permitted)

3.2 Operaciones de tratamiento, pago y atención de la salud [12](#treatment-payment-and-health-care-operations)

3.3 Autorización [12](#authorization)

3.4 Mínimo necesario [12](#minimum-necessary)

3.5 Declaraciones permitidas especiales [12](#special-permitted-disclosures)

4. Derechos individuales y operaciones de privacidad [13](#individual-rights-and-privacy-operations)

4.1 Resumen de los derechos [13](#rights-overview)

4.2 El acceso no es el mismo que la autorización [13](#access-is-not-the-same-as-authorization)

4.3 Archivo de solicitud defensible [13](#defensible-request-file)

5. Security Rule Foundations [14](#security-rule-foundations)

- 5.1 Requisitos generales [14](#general-requirements)
- 5.2 Necesario y direccional [14](#required-and-addressable)
- 5.3 Análisis de riesgos y gestión de riesgos [14](#risk-analysis-and-risk-management)
- 6. Salvaguardias administrativas [16](#administrative-safeguards)
 - 6.1 Examen de la actividad del sistema de información [16](#information-system-activity-review)
 - 6.2 Pruebas de contingencia [16](#contingency-evidence)
- 7. Salvaguardias físicas y técnicas [17](#physical-and-technical-safeguards)
 - 7.1 Principios de control técnico [17](#technical-control-principles)
- 8. Breach Notification Rule [18](#breach-notification-rule)
 - 8.1 presunción de parto y evaluación de cuatro factores [18](#breach-presumption-and-four-factor-assessment)
 - 8.2 Excepciones [18](#exceptions)
- 9. Business Associates and Vendor Oversight [19](#business-associates-and-vendor-oversight)
 - 9.1 Contenido del acuerdo comercial asociado [19](#business-associate-agreement-contents)
 - 9.2 debida diligencia [19](#due-diligence)
- 10. Parte 2 y Información Especial sobre Salud [20](#part-2-and-special-health-information)
 - 10.1 42 CFR Parte 2 [20](#cfr-part-2)
 - 10.2 Reglas especializadas y estatales [20](#specialized-and-state-rules)
 - 10.3 Estado de regla de salud reproductiva [20](#reproductive-health-rule-status)
- 11. Enforcement, State Law, and Current Developments [21](#enforcement-state-law-and-current-developments)
 - 11.1 OCR enforcement [21](#ocr-enforcement)
 - 11.2 Tigres de penalidad [21](#penalty-tiers)
 - 11.3 Preención de la ley [21](#state-law-preemption)
 - 11.4 Regla de Seguridad NPRM [21](#security-rule-nprm)
 - 11.5 Tecnologías de seguimiento en línea [21](#online-tracking-technologies)
- 12. Guía de requisitos reglamentarios completos [22](#complete-regulatory-requirements-guide)
 - 12.1 Regla de Seguridad [22](#security-rule)

12.2 Regla de Privacidad [22](#privacy-rule)

12.3 Breach Notification Rule [23](#breach-notification-rule-1)

12.4 Ejecución de la aplicación de la ley [23](#enforcement-and-preemption)

12.5 Método de verificación del cumplimiento [24](#compliance-verification-method)

12.6 Pruebas prácticas de verificación [25](#practical-verification-tests)

12.7 Confiabilidad de la prueba [25](#evidence-reliability)

13. Libro de juegos HIPAA del administrador [26](#managers-hipaa-playbook)

13.1 Preguntas para cada propietario [26](#questions-for-every-owner)

13.2 Dashboard mensual [26](#monthly-dashboard)

13.3 Errores comunes de gestión [26](#common-management-mistakes)

14. From Beginner to Junior HIPAA Analyst [27](#from-beginner-to-junior-hipaa-analyst)

14.1 Títulos de trabajo [27](#job-titles)

14.2 Trabajo junior típico [27](#typical-junior-work)

14.3 Prueba de cartera [28](#portfolio-proof)

15. Herramientas de código abierto para HIPAA Work [29](#open-source-tools-for-hipaa-work)

15.1 matriz de verificación de la herramienta a la adquisición [29](#tool-to-requirement-verification-matrix)

15.2 Cómo validar una herramienta antes de confiar en ella [30](#how-to-validate-a-tool-before-relying-on-it)

15.3 Paquete de pruebas de herramientas [31](#tool-evidence-package)

15.4 CISO Assistant [31](#ciso-assistant)

Inicio rápido [31](#quick-start)

Evidencia para retener [31](#evidence-to-retain)

15.5 Wazuh [32](#wazuh)

Inicio rápido [32](#quick-start-1)

Evidencia para retener [32](#evidence-to-retain-1)

15.6 OpenSCAP [32](#openscap)

Inicio rápido [32](#quick-start-2)

Evidencia para retener [32](#evidence-to-retain-2)

15.7 Greenbone Community Edition [32](#greenbone-community-edition)

Inicio rápido [32](#quick-start-3)

Evidencia para retener [32](#evidence-to-retain-3)

15.8 osquery [32](#osquery)

Inicio rápido [33](#quick-start-4)

Evidencia para retener [33](#evidence-to-retain-4)

15.9 Trivy [33](#trivy)

Inicio rápido [33](#quick-start-5)

Evidencia para retener [33](#evidence-to-retain-5)

15.10 OWASP ZAP [33](#owasp-zap)

Inicio rápido [33](#quick-start-6)

Evidencia para retener [33](#evidence-to-retain-6)

15.11 Keycloak [33](#keycloak)

Inicio rápido [34](#quick-start-7)

Evidencia para retener [34](#evidence-to-retain-7)

15.12 DefectDojo [34](#defectdojo)

Inicio rápido [34](#quick-start-8)

Evidencia para retener [34](#evidence-to-retain-8)

15.13 Velociraptor [34](#velociraptor)

Inicio rápido [34](#quick-start-9)

Evidencia para retener [34](#evidence-to-retain-9)

15.14 Agente de política abierta [34](#open-policy-agent)

Inicio rápido [34](#quick-start-10)

Evidencia para retener [35](#evidence-to-retain-10)

15.15 Recursos públicos gratuitos [35](#free-government-resource)

15.16 Lista de verificación de la gobernanza de los instrumentos [35](#tool-governance-checklist)

16. Fictional Healthcare Laboratory and Portfolio [36](#fictional-healthcare-laboratory-and-portfolio)

Proyecto 1 — Alcance y funciones [36](#project-1-scope-and-roles)

Proyecto 2 — Análisis de riesgos [36](#project-2-risk-analysis)

Proyecto 3 - Garantías de seguridad [36](#project-3-security-safeguards)

Proyecto 4 - Derechos de privacidad [36](#project-4-privacy-rights)

Proyecto 5 — Breach [36](#project-5-breach)

Proyecto 6 — Vendor [36](#project-6-vendor)

Proyecto 7 — Herramientas [36](#project-7-tools)

16.1 Portfolio ethics [36](#portfolio-ethics)

17. Plan de aprendizaje de 30 días [37] (#thirty-day-learning-plan)

17.1 hábito diario [37](#daily-habit)

18. Preparación de entrevistas [38](#interview-preparation)

¿Quién debe cumplir con HIPAA? [38](#who-must-comply-with-hipaa)

¿Qué es PHI? [38](#what-is-phi)

PHI versus ePHI? [38](#phi-versus-ephi)

¿Qué es mínimo necesario? [38](#what-is-minimum-necessary)

¿Qué es un análisis de riesgo HIPAA? [38](#what-is-a-hipaa-risk-analysis)

¿Direccionable significa opcional? [38](#does-addressable-mean-optional)

¿Cuál es el estándar de la brecha? [38](#what-is-the-breach-standard)

¿Cómo apoyan el cumplimiento los asociados empresariales? [38](#how-do-business-associates-support-compliance)

¿Cómo prueba que funciona una salvaguardia? [38](#how-do-you-prove-a-safeguard-works)

18.1 Respuesta del Administrador de 60 segundos [39](#managers-60-second-answer)

19. Plantillas y listas de verificación [40](#templates-and-checklists)

19.1 ePHI inventory fields [40](#ephi-inventory-fields)

19.2 Campos de registro de riesgos [40](#risk-register-fields)

19.3 Breach fact sheet [40](#breach-fact-sheet)

19.4 Lista de verificación BAA [40](#baa-checklist)

19.5 Lista de comprobación previa de la auditoría [41](#manager-pre-audit-checklist)

20. Glosario [42](#glossary)

21. Índice de asunto [44](#subject-index)

22. Referencias oficiales y estudio ulterior [45](#official-references-and-further-study)

1. HIPAA Foundations

Lo que HIPAA cubre, lo que no cubre, y cómo sus reglas principales funcionan juntas.

■img src="media/image1.png" estilo="width:6.15in;height:2.9808in" alt="Privacy, Security, Breach Notification, and Enforcement are connected." /

Figura 1. Las principales áreas de cumplimiento HIPAA

1.1 The HIPAA Rules

Area Silencio** ...

TENIDA Privacy Rule TENCIÓN Limita los usos y divulgaciones y da derechos de las personas
TEN PHI en formato electrónico, papel y oral TEN Silencio Seguridad Regla Silencio Protege PHI
electrónico TENIDO Salvaguardias administrativas, físicas y técnicas – Breach Notification
Rule TEN Requiere evaluación y notificación después de ciertas infracciones TEN PHI no
garantizado y documentado decisiones de riesgo TEN TENCIÓN TERRITORIO Explica
investigaciones y penas TENIENTES Quejas, exámenes de cumplimiento, pruebas, corrección
TENIDO tención Transacciones y conjuntos de códigos tención Estándariza las operaciones
electrónicas de salud

1.2 HIPAA no es una ley general de salud-datos

HIPAA se aplica a entidades cubiertas, socios comerciales y ciertos arreglos conexos. Una aplicación de fitness, empleador, escuela, seguro de vida o servicio directo a consumidor puede tener datos de salud sensibles sin ser una entidad cubierta HIPAA. Otras leyes federales y estatales todavía pueden aplicarse.

1.3 Punto de control de la ley actual

Importante: La actualización de la Regla de Seguridad HIPAA de diciembre 2024 es una regla propuesta, no la actual Regla de Seguridad final. Este manual explica la norma actual y etiqueta claramente la propuesta como un tema de desarrollo futuro. Silencio.

2. Alcance, Roles, PHI y ePHI

Cómo identificar entidades reguladas, información protegida, límites y responsabilidades.

■img src="media/image2.png" estilo="width:6.15in;height:3.27065in" alt="PHI es creado, utilizado, compartido, almacenado y destruido a través de su ciclo de vida." /

Figura 2. Ciclo de vida de la PHI

2.1 Entidades cubiertas

- Planes de salud

- Centros de atención sanitaria
- Proveedores de atención de salud que transmiten información electrónica en relación con una transacción cubierta

2.2 Empresas asociadas

Un socio de negocios realiza ciertas funciones o servicios para una entidad cubierta que implica PHI. Un subcontratista que crea, recibe, mantiene o transmite PHI en nombre de un socio comercial también puede ser un socio comercial. El estado viene de los hechos y reglas, no sólo de si se firma un contrato.

2.3 PHI and ePHI

La información sobre la salud protegida es una información de salud individualizada que se mantiene o transmite por una entidad o un asociado comercial cubiertos, con exclusión de determinados registros de educación y empleo. ePHI es PHI mantenido o transmitido electrónicamente. The Security Rule protects ePHI; the Privacy Rule protects PHI in any form.

2.4 De-identification

Silencio **Metodo**do Silencioso** Silencio

— — — — — Un experto cualificado determina y documenta que el riesgo de identificación es muy pequeño tención Expert qualifications, método, Hipótesis, reporte sometida Silencio Safe Harbor Silencio Eliminar los identificadores enumerados y no tienen ningún conocimiento real de que la información restante identifica a una persona identificadora lista de verificación, revisión de calidad, aprobación

*Manager checkpoint:** Requiere un análisis por escrito de alcance y función para cada entidad jurídica, servicio, producto, función del empleador, actividad de investigación, proveedor y flujo de datos. Silencio.

3. Regla de Privacidad: Usos y Divulgaciones

- Usos, autorizaciones, mínimo necesario, verificación, avisos y situaciones especiales*.

3.1 Necesario versus permitido

The Privacy Rule requires disclosure to the individual in certain rights situations and to HHS for enforcement. Permite muchos otros usos y divulgaciones cuando se cumplen las condiciones. La divulgación permitida no siempre es obligatoria; otras leyes y deberes profesionales pueden afectar la decisión.

3.2 Tratamiento, pago y operaciones de salud

Las entidades cubiertas pueden utilizar y divulgar PHI para operaciones de tratamiento, pago y atención de la salud bajo la regla. Los equipos todavía deben confirmar el propósito, el destinatario, el papel, la norma mínima necesaria aplicable, los avisos y otras condiciones.

3.3 Authorization

- Describir la información de manera específica y significativa.
- Nombrar o describir quién puede revelar y recibirlo.
- Declarar el propósito, la expiración y las declaraciones requeridas.
- Usar lenguaje claro y obtener firma y fecha.
- Rastrear la revocación y la dependencia ya tomada.
- Aplicar reglas especiales para notas de psicoterapia, marketing y venta de PHI.

3.4 Mínimo necesario

Cuando se aplica la norma mínima necesaria, se limitan los usos, las revelaciones y las solicitudes al PHI razonablemente necesarias para ello. Definir las funciones de la fuerza de trabajo, los protocolos de rutina, la revisión no rutinaria y la dependencia razonable. La norma tiene excepciones, incluyendo información o solicitudes de un proveedor de atención médica para el tratamiento.

3.5 Publicaciones permitidas especiales

Silencio **Situación** Silencio. tención requerida por la ley Silencio Identificar el requisito legal exacto y limitar la revelación Silencio Salud pública Silencio Verificar autoridad receptora y propósito permitido – Abuso, abandono o violencia doméstica – Aplicar las condiciones, consideraciones de seguridad y las reglas de aviso . TENCIÓN DE LA OPERVISIÓN DE LA Salud TENIDA Confirmar autoridad de supervisión y alcance Silencio Procedimiento judicial o administrativo Silencioso Orden de revisión, orden de citación, aviso, orden de protección y condiciones de objeción Silencioso cumplimiento de la ley Silencio Identificar el permiso preciso y verificar el solicitante – Investigación Silencio Confirmación de autorización, renuncia, revisión preparatoria o condiciones engañosas – Amenaza seria Aplicar condiciones de buena fe y de aplicación Silencio Remuneración de los Trabajadores Silencio Limite la divulgación a lo que la ley autoriza vivir

4. Derechos individuales y operaciones de privacidad

Cómo recibir, verificar, completar y documentar solicitudes de pacientes y miembros.

4.1 Sinopsis de derechos

Silencio **Justo** Silencioso **Tiempo típico** Silencio

----- confidencialidad Aviso de las prácticas de privacidad At required service, enrollment, posting, and revision points TENIDO Acceder TENIDO Generalmente 30 días; una extensión de 30 días con notificación por escrito oportuna TEN Verify, search designated record set, review exclusions, format, fees, delivery TEN tención Enmienda Silencio Generalmente 60 días; una extensión de 30 días con aviso Silencio Revisión, aceptar o negar, registros de enlaces, notificar a las partes Silencio Silencio Contabilidad de las revelaciones Silencio Generalmente 60 días; una extensión de 30 días con aviso Silencio Buscar registros, aplicar excepciones, entregar contabilidad eterna Silencioso petición de restricción Silencioso Revisión y respuesta; ciertas restricciones pagadas en el plan de salud deben ser aceptadas Silencio, bandera del sistema, control de aguas abajo Silencio Comunicaciones confidenciales Silencio Accommodate reasonable requests under the applicable rule Silencio Dirección alternativa, canal, manejo de seguridad – Reclamación Silencio No hay represalias; proceso bajo la política Silencioso Iniciar sesión, investigar, responder, mitigar, retener pruebas

4.2 El acceso no es el mismo que la autorización

El derecho de acceso de un individuo bajo 45 CFR 164.524 tiene su propio alcance, tiempo, negación, formato y reglas de tarifas. No aplique automáticamente un proceso de autorización o cree barreras que la regla de acceso no permita.

4.3 Archivo de solicitud defensible

- Solicitud y fecha de recepción
- Identidad y decisión personal-representativa
- Sistema de registro y sistemas registrados
- Exclusiones, negación revisable y análisis jurídico
- Formato, método de entrega y cálculo de honorarios
- Aviso de extensión cuando se utiliza
- Respuesta, prueba de entrega y fecha de terminación

5. Security Rule Foundations

Requisitos generales, flexibilidad, especificaciones requeridas y accesibles y pruebas.

Jim src="media/image3.png" style="width:6.15in;height:3.33266in" alt="Las salvaguardias administrativas, físicas y técnicas dependen del análisis de riesgos." /

Gráfico 3 HIPAA Garantías de seguridad

Requisitos generales

Garantizar la confidencialidad, la integridad y la disponibilidad de ePHI.

Proteger contra amenazas y peligros razonablemente previstos.

Proteger contra los usos o revelaciones inválidos razonablemente previstos.

Asegurar el cumplimiento de la fuerza laboral.

5.2 Requisitos y accesibles

Silencio **La adición no significa opcional:** Para una especificación abordable, evalúe si es razonable y apropiado. Aplicarlo cuando lo sea. Si no lo es, documente por qué e implemente una alternativa razonable y apropiada equivalente cuando existe. Silencio Silencio.

5.3 Análisis de riesgos y gestión de riesgos

1. Definir todos los límites de la ePHI y la entidad regulada.
2. Sistemas de mapa, aplicaciones, dispositivos, personas, ubicaciones, proveedores, redes, interfaces, copias de seguridad y medios de comunicación.
3. Identificar amenazas, vulnerabilidades, medidas existentes, probabilidad e impacto.
4. Determinar el riesgo consistentemente.
5. Asignar tratamientos, propietarios, recursos, fechas y autoridad de aceptación.
6. Retestar y actualizar después de cambios, incidentes, nuevas amenazas y fallos de control.

La actual Regla de Seguridad no establece una frecuencia de análisis de riesgo fijo. HHS guidance states the process should be ongoing and updated as needed.

6. Salvaguardias administrativas

Los procesos de gestión que convierten la política en protección repetible.

Silencio** Silencio** Silencio----- TEN
164.308(a)(1) TENIDO Proceso de gestión de la seguridad TENIDO Realizar análisis de riesgos, gestión de riesgos, sanciones y revisión de la actividad del sistema de información. Silencio
Análisis de riesgos, plan de tratamiento, sanciones, pruebas de revisión de registros tención
164.308(a)(2) Silencio Assigned security responsibility – Designate the official responsible for Security Rule policies and procedures. Silencio Descripción del papel, nombramiento, línea de presentación de informes Silencio 164.308(a)(3) Silencio Seguridad de la fuerza de trabajo
Silencio Autorizar, supervisar, limpiar y eliminar rápidamente el acceso a la fuerza de trabajo.
Silencio Aprobaciones de acceso, selección, pruebas de rescisión Silencio 164.308(a)(4) Silencio
Gestión de acceso a la información Silencio Acceso a control basado en función y necesidad, incluyendo establecimiento y modificación. Silencio Matriz de acceso, aprobaciones, revisiones periódicas Silencio 164.308(a)(5) Silencio Seguridad conciencia y entrenamiento Silencio
Entrenar a la fuerza de trabajo y abordar recordatorios, malware, monitoreo de registros y gestión de contraseñas. Silencio Entrenamiento, simulaciones, recordatorios, seguimiento tención 164.308(a)(6) Silenciosos procedimientos de incidentes de seguridad Silencio
Identificar, responder, mitigar, documentar e informar de incidentes. Silencio Plan de

incidencias, entradas, evidencia, lecciones Silencio 164.308(a)(7) Silencio Plan de Contingencia Silencio Respaldos operativos, recuperación en casos de desastre, modo de emergencia, pruebas y análisis de crítica. informes de respaldo, pruebas de restauración, ejercicios, planes de recuperación tención 164.308(a)(8) Silencio Evaluación Silencioso Realizar evaluaciones técnicas y no técnicas periódicas después de los cambios pertinentes. TENIDO Alcance de evaluación, conclusiones, plan de corrección Silencio 164.308(b) Silencio Acuerdos asociados para empresas tención Uso de contratos u otros arreglos que requieren salvaguardias apropiadas. TEN BAA, due diligence, monitoring TENIDO

6.1 Revisión de la actividad del sistema de información

Definir qué registros de auditoría, informes de acceso, eventos de seguridad, informes de excepción y alertas se revisan; con qué frecuencia; por quién; cómo se mantienen las pruebas; y cómo la actividad sospechosa se convierte en un incidente o acción correctiva.

6.2 Contingency evidence

- Trabajo de respaldo e informes de fracaso
- Diseño de copia de seguridad sin conexión o de otro modo protegido
- Pruebas de restauración documentadas
- Procedimientos de emergencia
- Ejercicios de recuperación de desastres
- Aplicación crítica y análisis de datos
- Lecciones, propietarios y fechas

7. Salvaguardias físicas y técnicas

Facilidades, estaciones de trabajo, medios de comunicación, identidad, acceso, auditoría, integridad y controles de transmisión.

Silencio** Silencio** Silencio...

tención 164.310(a) tención Controles de acceso a las instalaciones Silencio Limitar el acceso físico al permitir el acceso autorizado y la continuidad. Plan de instalación, registros de visitantes, registros de mantenimiento tención 164.310(b) Silencio Uso de estaciones de trabajo Silencio Definir funciones adecuadas y entorno físico para estaciones de trabajo usando ePHI. política de estaciones de trabajo, capacitación, observaciones Silencio 164.310(c) Silencio Seguridad de la estación de trabajo Silencio Restringir el acceso físico a estaciones de trabajo que acceden a ePHI. tención Localizaciones seguras, pantallas, controles de dispositivos TEN 164.310(d) TENIDO Controles de dispositivos y medios de comunicación TENIDO Recibimiento, movimiento, reutilización, respaldo, eliminación y rendición de cuentas. Silencio Inventario, cadena de custodia, prueba de limpieza y destrucción Silencio 164.312(a) Silencio Control de acceso Silencio Uso de IDs únicos, acceso de emergencia, y controles de logotipo y cifrado

adecuados. Ajustes de IAM, prueba de emergencia, registro de cifrado tención 164.312(b) Silencio Controles de auditoría tención Record y examinar la actividad en sistemas que contengan o utilicen ePHI. Silencios, calendario de revisión, registros de investigación Silencio 164.312(c) Silencio Integridad Silencio Protege el ePHI de alteración o destrucción indebida. Controles de integridad, controles de cambio, validación Silencio 164.312(d) Silencio Persona o entidad autenticación Silencio Verificar que una persona o entidad que busca acceso es la reclamada. – Ajustes de autenticación, MFA, registros de identidad Silencio 164.312(e) Silencio Seguridad de la transmisión Silencioso Protege ePHI contra el acceso no autorizado mientras se transmite. – Encriptación, protocolos seguros, pruebas de arquitectura Silencio 164.314 Silencio Requisitos organizacionales Silencio Abordar contratos comerciales asociados y requisitos del plan de salud grupal. Ø Contratos, documentos del plan, revisiones TEN 164.316 TENRI Políticas, procedimientos y documentación TEN Aplicar políticas razonables y conservar la documentación necesaria durante seis años. Silencio Políticas aprobadas, versiones, pruebas de retención de seis años

7.1 Principios de control técnico

- Dar a cada usuario una identidad única.
- Usar menos privilegios y la eliminación oportuna.
- Proteger el acceso privilegiado y de emergencia.
- Grabar actividad significativa y revisarla.
- Use una autenticación fuerte adecuada para el riesgo.
- Proteger el ePHI en reposo y en tránsito basado en el análisis documentado.
- Prueba de integridad, recuperación y eficacia de control.
- Gestionar excepciones con el propietario, razón, compensación de controles, vencimiento y aprobación.

8. Regla de Notificación de Breach

Cómo evaluar los incidentes de PHI no garantizados y cumplir con las obligaciones de notificación.

■img src="media/image4.png" estilo="Ancho:6.15in; Altura:3.45654in" alt="Descubrimiento, contención, evaluación, notificación y mejora de un proceso." /

Figura 4. Flujo de trabajo de ruptura HIPAA

8.1 Breach presumption and four-factor assessment

Se presume que el uso o la divulgación inadmisibles de PHI es una violación a menos que la entidad cubierta o asociado comercial demuestre una baja probabilidad de que el PHI estuviera comprometido. Evaluar al menos la naturaleza y el alcance del PHI y la probabilidad de reidentificación, la persona no autorizada, si el PHI fue adquirido o visto en realidad, y el alcance de la mitigación.

Silencio **Notificación** Silencio ** Sinopsis del nombramiento** Silencio

----- La vida ----- Silencio
Individuos TENIDO Sin demora irrazonable y a más tardar 60 días después del descubrimiento
TENIDO Contenido, entrega, aviso sustitutorio, prueba TEN HHS — 500 o más TENIDO Bajo el
cronograma de presentación de informes contemporáneos de la regla Silencio HHS — menos de
500 Silencio Presentación de informes anuales, a más tardar 60 días después de la finalización
del año civil Silencio Pequeño tronco y sumisión — Medios de comunicación tención Más de
500 residentes de un estado o jurisdicción vivieron el recuento de Jurisdicción, aviso de los
medios Silencio Business Associate to covered entity TEN sin demora irrazonable y a más tardar
60 días TENENCIA Fecha de descubrimiento, identidades si se conoce, hechos y aviso TENIDO

8.2 Excepciones

La definición de incumplimiento contiene excepciones estrechas que implican cierto acceso a la fuerza de trabajo involuntario o involuntario y creencias de buena fe de que un receptor no autorizado no podría conservar razonablemente la información. Document facts and legal review before relying on an exception.

9. Business Associates and Vendor Oversight

- Contratos, subcontratistas, diligencia debida, vigilancia, incidentes y terminación*.

9.1 Contenido del acuerdo comercial asociado

Usos y divulgaciones permitidos y requeridos

No utilizar o divulgar más allá del contrato o la ley

Garantías adecuadas y cumplimiento de las Reglas de Seguridad para el ePHI

Breach, incidente, y reportajes no asegurados-PHI

Apoyo a los derechos de acceso, enmienda y contabilidad

PHI disponibilidad for HHS compliance review

Devolución o destrucción cuando sea posible

Acuerdos de subcontratistas con las mismas restricciones aplicables

Derechos de rescisión por violación material

9.2 Due diligence

Area Silencio. ¿Qué PHI/ePHI, propósito, servicios, ubicaciones e interfaces? tención Flujo de datos, inventario, arquitectura TEN Seguridad TENIDO Análisis de riesgos, cifrado, identidad, registro, vulnerabilidad, respaldos, respuesta a incidentes? — Políticas, pruebas, informes, remediación — Privacidad Silencio mínimo necesario, acceso a la fuerza de trabajo, apoyo a los derechos, controles de divulgación? procedimientos, roles, muestras ¿Quién, con qué propósito, bajo qué acuerdo? — Subprocesador lista y términos ¿Cuándo y cómo informará el informe de

BA y cooperará? — BAA, ejercicio, contactos ¿Cómo acceder al final y PHI será devuelto o destruido? Silencio Plan de salida, prueba de eliminación, registro de riesgo residual

Silencio ** Punto de administración:** Un BAA firmado es necesario en muchas relaciones, pero no reemplaza la diligencia debida, la gestión de riesgos, el control de acceso, la vigilancia o la coordinación de incidentes. Silencio Silencio.

10. Parte 2 y Información Especial sobre Salud

- Registros de trastornos de uso de sustancias, salud mental, genética y otras reglas de superposición.*

10.1 42 CFR Part 2

La Regla Final 2024 Parte 2 entró en vigor el 16 de abril de 2024, y el cumplimiento fue requerido para el 16 de febrero de 2026. Alinea disposiciones importantes de consentimiento, cumplimiento, notificación de incumplimiento y aviso más estrechamente con HIPAA, manteniendo al mismo tiempo protecciones especiales para registros de programas de trastorno de uso de sustancias asistidas federalmente.

Determinar si la organización es un programa Parte 2, titular legal o receptor.

Utilice el consentimiento de la Parte 2 actual, redisclosure, queja, incumplimiento y requisitos de aviso.

No asuma que el permiso HIPAA solo siempre resuelve los deberes de la Parte 2.

Actualizar avisos de prácticas de privacidad y avisos de pacientes de la Parte 2 según sea necesario para el cumplimiento del 16 de febrero de 2026.

10.2 Reglas especializadas y estatales

La legislación estatal puede ser más estricta que la HIPAA y puede imponer normas especiales para la salud mental, el VIH, la salud reproductiva, la genética, los menores, la telesalud, los datos biométricos o el aviso de incumplimiento. Otras reglas federales pueden aplicarse a registros de trastornos del uso de sustancias, registros educativos, investigación clínica, bloqueo de información, aplicaciones de salud del consumidor y transferencias de datos sensibles.

10.3 Situación de la norma de salud reproductiva

Estado actual: Una orden judicial federal de 18 de junio de 2025 dejó la mayoría de la regla 2024 HIPAA de privacidad en salud reproductiva. El HHS declara que sólo quedaban ciertas modificaciones del Aviso de Privacidad Prácticas. Verifique la página actual del HHS y el asesoramiento legal antes de utilizar cualquier flujo de trabajo de 2024 certificados o salud reproductiva. Silencio Respuesta de Dios.

11. Ejecución, derecho del Estado y desarrollos actuales

Denuncias, investigaciones, sanciones, preenciones, decisiones judiciales y cambios propuestos.

11.1 OCR enforcement

- Recibir e investigar denuncias.
- Realizar exámenes y auditorías de cumplimiento.
- Solicitar registros y cooperación.
- Busque el cumplimiento voluntario y la acción correctiva.
- Introduzca acuerdos de resolución y planes de acción correctiva.
- Imposibilidad de multas civiles cuando estén autorizadas.
- Remitir posibles violaciones criminales al Departamento de Justicia.

11.2 Penalty tiers

El análisis de la pena civil considera el conocimiento, la causa razonable, el abandono, la corrección, la naturaleza y el alcance, el daño, la historia, la situación financiera y otros factores. Las cantidades de dólares se ajustan periódicamente. Verifique las cantidades actuales de HHS y Registro Federal en lugar de confiar en un gráfico antiguo.

11.3 State-law preemption

HIPAA generalmente previene la ley estatal contraria, pero las reglas contienen excepciones, incluyendo para ciertas protecciones de privacidad más estrictas y leyes de salud pública o reporte. Mantener una matriz de estado y obtener revisión legal para cada ubicación de servicio y población individual.

Regla de Seguridad NPRM

HHS propuso cambios importantes en la Regla de Seguridad en un aviso publicado el 6 de enero de 2025, incluyendo inventarios de activos más específicos, mapeo de redes, análisis de riesgos, pruebas, cifrado, autenticación multifactorial, segmentación, recuperación y derechos de verificación asociados al negocio. A partir de la publicación de este manual de julio de 2026, los materiales oficiales de HHS siguen identificándolo como norma propuesta. Supervisarla, planificar la preparación, pero no describir el texto propuesto como ley final actual.

11.5 Tecnologías de seguimiento en línea

HHS observa que un tribunal abandonó parte de su orientación tecnológica de seguimiento en relación con una dirección IP combinada con una visita a una página web pública no autorizada sobre las condiciones de salud o los proveedores. Las tecnologías de seguimiento de los inventarios, verifican los datos y el contexto reales, examinan los contratos y las revelaciones y utilizan la orientación jurídica actual en lugar de las hipótesis generales.

12. Guía de requisitos reglamentarios completos

Una referencia práctica a los requisitos actuales de Privacidad, Seguridad y Notificación de Breach.

Regla de Seguridad

Silencio **Citación** Silencio **Requisito** Silencio **Manager action** Silencio** Silencio

— — — — Silencio 164.306 Silencio Reglas generales Silencio Protege la confidencialidad, la integridad y la disponibilidad del ePHI; aborda las amenazas anticipadas y los usos inválidos. programa de seguridad, decisiones de riesgo, análisis de flexibilidad TEN 164.308(a)(1) TENIDO Proceso de gestión de la seguridad TENIDO Realizar análisis de riesgos, gestión de riesgos, sanciones y revisión de la actividad del sistema de información. Silencio Análisis de riesgos, plan de tratamiento, sanciones, pruebas de revisión de registros tención 164.308(a)(2) Silencio Assigned security responsibility – Designate the official responsible for Security Rule policies and procedures. Silencio Descripción del papel, nombramiento, línea de presentación de informes Silencio 164.308(a)(3) Silencio Seguridad de la fuerza de trabajo Silencio Autorizar, supervisar, limpiar y eliminar rápidamente el acceso a la fuerza de trabajo. Silencio Aprobaciones de acceso, selección, pruebas de rescisión Silencio 164.308(a)(4) Silencio Gestión de acceso a la información Silencio Acceso a control basado en función y necesidad, incluyendo establecimiento y modificación. Silencio Matriz de acceso, aprobaciones, revisiones periódicas Silencio 164.308(a)(5) Silencio Seguridad conciencia y entrenamiento Silencio Entrenar a la fuerza de trabajo y abordar recordatorios, malware, monitoreo de registros y gestión de contraseñas. Silencio Entrenamiento, simulaciones, recordatorios, seguimiento tención 164.308(a)(6) Silenciosos procedimientos de incidentes de seguridad Silencio Identificar, responder, mitigar, documentar e informar de incidentes. Silencio Plan de incidencias, entradas, evidencia, lecciones Silencio 164.308(a)(7) Silencio Plan de Contingencia Silencio Respaldos operativos, recuperación en casos de desastre, modo de emergencia, pruebas y análisis de crítica. informes de respaldo, pruebas de restauración, ejercicios, planes de recuperación tención 164.308(a)(8) Silencio Evaluación Silencioso Realizar evaluaciones técnicas y no técnicas periódicas después de los cambios pertinentes. TENIDO Alcance de evaluación, conclusiones, plan de corrección Silencio 164.308(b) Silencio Acuerdos asociados para empresas tención Uso de contratos u otros arreglos que requieren salvaguardias apropiadas. TEN BAA, due diligence, monitoring TENIDO tención 164.310(a) tención Controles de acceso a las instalaciones Silencio Limitar el acceso físico al permitir el acceso autorizado y la continuidad. Plan de instalación, registros de visitantes, registros de mantenimiento tención 164.310(b) Silencio Uso de estaciones de trabajo Silencio Definir funciones adecuadas y entorno físico para estaciones de trabajo usando ePHI. política de estaciones de trabajo, capacitación, observaciones Silencio 164.310(c) Silencio Seguridad de la estación de trabajo Silencio Restringir el acceso físico a estaciones de trabajo que acceden a ePHI. tención Localizaciones seguras, pantallas, controles de dispositivos TEN 164.310(d) TENIDO Controles de dispositivos y medios de comunicación TENIDO Recibimiento, movimiento, reutilización, respaldo, eliminación y rendición de cuentas. Silencio Inventario, cadena de custodia, prueba de limpieza y destrucción Silencio 164.312(a) Silencio Control de acceso Silencio Uso de IDs únicos, acceso de emergencia, y controles de logotipo y cifrado adecuados. Ajustes de IAM, prueba de emergencia, registro de

12.2 Privacy Rule

164.502 TENIDO Reglas generales de uso y divulgación TENIDO Utilizar o divulgar PHI únicamente según sea necesario o permitido; aplicar reglas de socios comerciales y personas fallecidas. Silencio Matriz de uso/disclosure, aprobaciones, registros de la revelación Silencio 164.504 Silencio Requisitos organizacionales Silencio Dirija a las entidades híbridas, grupos afiliados, socios empresariales y límites patrocinados por planes. – Designations, BAA, documentos de plan, firewalls – Silencio 164.506 Silencio Tratamiento, pago y operaciones Silencio Permite definir usos y divulgaciones de TPO y prácticas de consentimiento conexas. Silencio TPO mapa de propósito, aviso, acceso a la función TEN 164.508 ANTE Autorizaciones ANTE Requiere una autorización válida por escrito para usos y divulgaciones no permitidas de otra manera, incluyendo reglas especiales de autorización. Formulario de autorización, revocación, prueba de revelación TEN 164.510 TENIDO Oportunidad de acordar o objetar TENIDOS directorios de instalaciones y participación en cuidado o pago después de dar una oportunidad adecuada cuando sea necesario. Silencio Registro de preferencias, verificación de identidad y relación – TEN 164.512 TENIDO Usos y revelaciones sin autorización o oportunidad TENIDO Permite actividades específicas tales como requisitos por ley, salud pública, supervisión, judicial, cumplimiento de la ley, investigación y situaciones graves cuando se cumplen las condiciones. – Base legal, solicitud, verificación, aprobación, registro de la información TEN 164.514 TENIDO Otros requisitos de uso y divulgación TENIDO Cubre la deidentificación, códigos de reidentificación, mínimo necesario, conjuntos de datos limitados, acuerdos de uso de datos, recaudación de fondos y verificación. Silencio Método, determinación de expertos, DUA, verificación, examen mínimo necesario Silencio 164.520 Silencioso Aviso de prácticas de privacidad Silencio Requiere un aviso claro describiendo usos, revelaciones, deberes, derechos, quejas y contactos. NPP actual, distribución, reconocimiento, sitio web Silencio 164.522 Silencio Solicitudes de protección de la privacidad Silencio cubre restricciones y comunicaciones confidenciales, incluyendo la aceptación requerida de ciertas restricciones

pagadas en total a los planes de salud. Solicitud, decisión, bandera del sistema, método de comunicación Silencio 164.524 Silencio Acceso Silencio Proporciona acceso a PHI en un conjunto de registros designados, generalmente dentro de 30 días, sujeto a exclusiones, reglas de negación, formato y tarifas permitidas. Silencio Solicitud de registro, búsqueda, revisión de la negación, entrega, cálculo de tarifas tención 164.526 Silencioso Enmienda Silencio Permite a las personas solicitar una enmienda; requiere decisiones, avisos, declaraciones de desacuerdo y vinculación récord. Silencio Solicitud, decisión, enmienda o denegación, notificaciones Silencio 164.528 Silencio Contabilidad de las revelaciones Silencio Requiere una contabilidad de ciertas revelaciones durante el período de seis años aplicable, con excepciones. Silencio Registro de información, solicitud, contabilidad, fecha de respuesta tención 164.530 Silencio Requisitos administrativos Silencio Requiere personal de privacidad, capacitación, salvaguardias, quejas, sanciones, mitigación, no represalias, políticas y documentación. Silencio Función, capacitación, denuncias, sanciones, políticas TEN 164.532–535 ANTERI Transition and compliance provisions TEN Aborda las reglas de transición y las fechas de cumplimiento. tención Registro legal, decisión de transición, fecha de aprobación

12.3 Breach Notification Rule

Silencio **Citación** Silencio **Requisito** Silencio **Plain meaning** Silencio** Silencio

----- La vida- TEN 164.400 TENIDO Aplicabilidad ANTE Aplica el subpartido de notificación de incumplimiento a entidades cubiertas y asociados comerciales. – Ámbito y análisis de roles TEN 164.402 TENIDO Definiciones y evaluación del riesgo de incumplimiento ANTERI Se presume una violación de PHI no garantizado a menos que la entidad muestre una baja probabilidad de compromiso utilizando los factores requeridos. Silencio Evaluación de cuatro factores, hechos, mitigación, aprobación tención 164.404 Silencioso Aviso a las personas que viven Notificar a las personas afectadas sin demora irrazonable y a más tardar 60 días después del descubrimiento; cumplir con el contenido y las reglas de entrega. tención Notificación, búsqueda de direcciones, entrega y aviso sustituto tención 164.406 Silencioso Aviso a los medios de comunicación Silencio Por infracciones que afectan a más de 500 residentes de un estado o jurisdicción, notifique a los medios prominentes dentro del período requerido. Silencio Cuenta por jurisdicción, aviso de los medios de comunicación, prueba de entrega TEN 164.408 TENIDO NOTICIA A LA SECRETARÍA ANTERIVISIÓN El informe viola el HHS bajo las reglas de tiempo para 500 o más y menos de 500 individuos. TEN HHS submission, annual small-breach log TEN Silencio 164.410 Silencio Aviso por un socio de negocios Silencio A BA debe notificar a la entidad cubierta sin demora irrazonable y a más tardar 60 días, con identificación y hechos disponibles. TEN BA aviso, fecha de descubrimiento, información de la persona afectada TEN 164.412 TENIDO Aplazamiento de la aplicación de la ley ANTERIOR Cuando una declaración de cumplimiento de la ley calificada cumple con la norma. tención Registro de solicitud escrita o oral y cálculo de retraso Silencio 164.414 Silencio Requisitos administrativos y carga de la prueba Silencio Aplicar capacitación laboral, políticas, no represalias, documentación y prueba de que se hicieron o no se requerían avisos. políticas, capacitación, evaluación del riesgo, pruebas de notificación

12.4 Enforcement and preemption

Silencio ** Área de localización** Silencio** Silencio

La vida eterna... tención 45 CFR Parte 160 Subparte B Silencio Preemption of state law TEN
Mantener la matriz legal y el camino de escalada TENIENDO revisión de la ley del Estado,
decisión de la abogada Silencio Parte 160 Subpart C Silencio Cumplimiento e investigaciones
Silencio Cooperate, preserve los hechos, evite represalias Silencio Reclamación y archivo de
respuesta tención Parte 160 Subpartes D–E Silencio Penal civil sanciones y procedimientos

12.5 Método de verificación del cumplimiento

Una prueba de verificación debe conectar un requisito a operaciones reales y pruebas fiables.
No debe comenzar con una captura de pantalla o un informe de herramienta. Comience con el
riesgo, entidad regulada, límite ePHI, requisito y control que la administración dice que está
operando.

Altura:3.56987in” alt=“Empieza con el requisito y el alcance, prueba el control, las excepciones
correctas y la prueba antes de concluir.” / Propiedad

Gráfico 6 Ciclo de verificación del cumplimiento

- Definir el requisito, riesgo, control, propietario, frecuencia, sistemas, periodo y evidencia esperada.
- Obtener la población completa para el período y probar si es completa y precisa.
- Seleccione una muestra basada en el riesgo que cubra los tiempos, sistemas, ubicaciones, propietarios y artículos inusuales.
- Inspeccione pruebas y, cuando sea práctico, reperforme o confirme independientemente el resultado de control.
- Record excepciones con el requisito exacto, hechos, causa, EPHI afectado, duración, probabilidad e impacto.
- Assign corrective action, owner, due date, interim protection, and escalation.
- Reprueba la corrección y confirma que funciona a través de la población afectada, no sólo por un ejemplo.
- Escribir una conclusión que establece alcance, período, trabajo realizado, resultado, excepciones y limitaciones.

12.6 Pruebas de verificación práctica

Silencio **Área de control** Silencioso **Populación y muestra** Silencio** Silencio

TENIDO Acceso terminado TEN Todas las terminaciones de la fuerza laboral en el período; muestra de salidas de mayor riesgo y corrientes TENIDO Comparar tiempo de terminación de recursos humanos con cuenta, insignia, acceso remoto, correo electrónico, EHR, y acceso privilegiado desactivación; inspecciones TENIDO lista completa de recursos humanos, IAM y registros del sistema, entradas, aprobaciones, tiempo de desactivación, excepción y retest tención Revisión periódica de acceso Silencio Todos los comentarios requeridos por sistema y período; sistemas de muestra con ePHI y roles privilegiados Silencio Confirmación completa de la población de usuarios, evaluador calificado, necesidad de roles, decisiones, absorciones, fecha de finalización y seguimiento Silencioso exportación de usuarios, pruebas de revisores, pasajes de eliminación, seguimiento del punto final, conclusión TENIDO Revisión de la actividad del sistema de información permanente Todas las revisiones diarias, semanales o mensuales programadas; muestra durante todo el período Silencio Inspeccione los registros de fuentes, cobertura de alerta, identidad de revisor, investigación, escalada y pruebas retenidas SIEM report, review record, ticket, decision, unresolved gap TEN Vulnerability management TEN All in-scope assets and findings; select critical, high, aged, and accepted findings TEN Confirmación de cobertura y credenciales de escaneado, validación de hallazgos, comparación de plazos, corrección de inspección, y recan ANTERIA inventario, ajustes de escaneo, informe, ticket, excepción, rescane, riesgo residual – Respaldos y recuperación Silencio Todos los trabajos de copia de seguridad y las pruebas de restauración necesarias; éxito de la muestra, fracaso y eventos de recuperación Silencio Inspeccione el estado de trabajo, alertas de fracaso, respuesta, copias protegidas, restaurar evidencia, objetivo de recuperación, y lecciones pendientes . TEN Seguridad incidentes e infracciones Silencio Población total de incidentes reconciliada con alertas, mostrador de ayuda, privacidad y troncos de incumplimiento Clasificación de pruebas, contención, evaluación de cuatro factores, tiempo de notificación, mitigación y cierre del archivo Silencio Incident, evaluación de riesgos, avisos, aprobación, acción correctiva, retest Silencio TEN Business Associates – Proveedores completos y población de BA; muestre proveedores de alto riesgo, nuevos, cambiados y rescindidos TEN VACÍFICO, términos BAA, debida diligencia, subcontratistas, pruebas de seguridad, incidentes, cambios y salida ANTERIOR inventario de proveedores, BAA, evaluación, hallazgos, monitoreo, destrucción o prueba de retorno TENIDO Silencio Derechos individuales Todo acceso, enmienda, restricción, comunicación confidencial, contabilidad y solicitudes de denuncia Test identity, scope, search, deadlines, extension, denial review, fee, delivery, and kept result tención Formación y sanciones Ocupación Personal completo y población de contratistas; funciones de muestra, nuevos alquileres, estudiantes fallecidos e incidentes Silencio Comparar asignaciones con población laboral, tiempo de culminación de pruebas, contenido, seguimiento y sanciones cuando sea aplicable Ø Roster, informe de terminación, recordatorios, historial de sanción, revisión de la gestión

12.7 Confiabilidad de la evidencia

Silencio **La calidad de la prueba** Silencioso** Silencio

TEN Weak Silencio Declaración verbal, captura de pantalla no fechada, exportación parcial o resumen creado por el propietario sin prueba de fuente TEN Solicitar datos fuente, fecha, alcance, identidad del sistema, revisor y

población completa TEN UTILIZADO TENIDO Informe del sistema Dated ligado al alcance y el período correctos TEN Confirmar configuración, integridad, acceso e interpretación TEN – Resultado generado por el sistema, además de revisión independiente, decisiones, entradas, corrección y retestigo – Trace la cadena completa y registro de cualquier limitación

Silencio **Regla de verificación:** Una búsqueda de herramientas es una entrada, no una conclusión. La verificación del cumplimiento requiere alcance, datos completos, examen humano, contexto jurídico y normativo, medidas correctivas y pruebas de que el control funciona con el tiempo. Silencio.

13. Libro de juegos HIPAA de Manager

Las preguntas, los paneles, las reuniones y los administradores de decisiones deben controlarse.

13.1 Preguntas para cada propietario

- ¿Qué PHI o EPHI está involucrado?
- ¿Qué entidad cubierta o papel asociado comercial se aplica?
- ¿Qué uso, divulgación o acceso está permitido y necesario?
- ¿Dónde fluye la información y permanece?
- ¿Quién tiene acceso y quién lo revisa?
- ¿Qué amenazas y vulnerabilidades le afectan?
- ¿Qué salvaguardia se aplica y dónde está la evidencia?
- ¿Qué proveedores y subcontratistas están involucrados?
- ¿Cómo funcionarán los derechos, los incidentes y la eliminación?
- ¿Quién acepta el riesgo residual y por qué autoridad?

13.2 Dashboard mensual

Area Silencio ** Cuestión del personal Silencio.** tención Análisis de riesgos ¿Están todos los sistemas, sistemas, ubicaciones y cambios cubiertos? Verde / Amarillo / Rojo tención de riesgo permanente ¿Hay altos riesgos asignados, financiados y programados? Verde / Amarillo / Rojo Silencio ¿Estaban a bordo, cambios, revisiones y terminación completadas? Verde / Amarillo / Rojo tención Revisión de la actividad Silencio ¿Se revisan registros y alertas con pruebas? Verde / Amarillo / Rojo TEN Vulnerabilidades ANTE ¿Son los hallazgos validados, priorizados, fijos y probados? Verde / Amarillo / Rojo – Backups Silencio ¿Han tenido éxito las copias de seguridad y las pruebas de restauración? Verde / Amarillo / Rojo ¿Fueron hechos, fallos y avisos oportunos? Verde / Amarillo / Rojo TEN VENTOS ANTERIENTE ¿Son controladas BAAs, diligencia debida, incidentes y salidas? Verde / Amarillo / Rojo Silencio ¿Son solicitudes completas, precisas, seguras y oportunas? Verde / Amarillo / Rojo

13.3 Errores comunes de gestión

- Tratar a HIPAA como un evento anual de entrenamiento.
- Limitar el análisis de riesgos al registro electrónico de salud.
- Llamar las especificaciones de dirección opcional.
- Firmar una BAA sin vigilar al vendedor.
- Ignorar dispositivos médicos, plataformas de nube, respaldos, interfaces y soporte remoto.
- Realizar escaneos sin validar, corregir y retestar hallazgos.
- Retrasar la escalada de incidentes hasta que se conozca todo hecho.
- Usando la seguridad propuesta Texto de la regla como si fuera definitivo.
- Ignorando más estrictos requisitos estatales.

14. From Beginner to Junior HIPAA Analista

Un camino seguro y honesto a la privacidad, seguridad y cumplimiento.

■img src="media/image6.png" style="width:6.15in;height:3.31039in" alt="Aprendizaje, mapeo, pruebas, documentación y aplicación de empleo forman una trayectoria profesional". /

Figura 5. Vía analista Junior HIPAA

14.1 Títulos de trabajo

Junior HIPAA Compliance Analyst

Healthcare GRC Analista

Privacy Operations Analyst

Análisis del cumplimiento de la seguridad de la información

Análisis del riesgo de terceros — Salud

Health Information Privacy Analyst

Análisis del riesgo de seguridad

HIPAA Program Coordinator

14.2 Típico trabajo junior

- Actualizar los inventarios de PHI, ePHI, sistema, dispositivo y proveedores.
- Reunir análisis de riesgos y salvaguardar pruebas.

- Revisar las muestras de acceso, terminación, entrenamiento, registro, respaldo y vulnerabilidad.
- Rastrear BAAs, diligencia debida, acciones correctivas y fechas de expiración.
- Coordinar los derechos individuales y los registros de divulgación.
- Preparar plazos de incidentes y datos de evaluación de infracciones.
- Escribir conclusiones claras sin hacer conclusiones legales sin apoyo.
- Seguir la remediación y retener la prueba de retesta.

14.3 Portafolio proof

Silencio **Skill** Silencio** Silencio— La vida— Silencioso encubierto-entidad y función asociativa de negocios memo tención cartografía de datos Silencioso ePHI ciclo de vida, inventario del sistema y diagrama de flujo de datos TEN Ø Riesgo Silencioso análisis de riesgos y registro de tratamiento TEN Seguridad TENIDA Matriz de salvaguardia con muestras de evidencia TEN Privacidad TENIDO Adhesión de acceso y archivos de divulgación Respuesta del incidente Silencio Breach: evaluación de cuatro factores y decisión de notificación Silencioso riesgo de vendedor Silencio Lista de verificación BAA, diligencia debida y plan de acción correctiva Silencio Manejo comunicación Silencio Una página dashboard y resumen de riesgo ejecutivo

Silencio ** Honra sincera:** Una cartera de laboratorio es el trabajo de formación, no la experiencia profesional. Etiqueta como ficticio, protege toda la información, y explica lo que requiere examen experto o legal. Silencio.

15. Herramientas de código abierto para el trabajo HIPAA

- Enlaces oficiales, inicios rápidos seguros, pruebas y limitaciones.*

tención **Metodología primero:** Una herramienta puede apoyar un proceso de salvaguardia o evidencia. No puede certificar el cumplimiento de HIPAA, sustituir el análisis de riesgo, o decidir si una revelación o violación es legal. — Silencio.

Silencio **Herramienta** Silencio— TENIDO CISO Assistant TENIDO GRC, risks, controls, evidence TENIDO Análisis de riesgos, operación de salvaguardia, evidencia o remediación tención Wazuh — SIEM, monitoreo de puntos finales, integridad de archivos TENIDO Análisis de riesgos, operación de salvaguardia, evidencia o remediación TENIDO TEN OpenSCAP TENIDO Evaluación de la configuración de Linux ANTE Análisis de riesgos, operación de salvaguardia, evidencia o remediación Silencio Greenbone Community Edition — Vulnerability escanear — Análisis de riesgos, operación de salvaguardia, evidencia o remediación osquery Silencio Inventario y consultas de Endpoint Análisis de riesgos, operación de salvaguardia, evidencia o remediación tención Trivy Silencio Código, imagen, secreto y configuración escaneado rígido Análisis de riesgos, operación de salvaguardia, evidencia o remediación TENIDO Silencio OWASP ZAP TENIDO Pruebas autorizadas de aplicación web TENIDO Análisis de riesgos, operación de salvaguardia, evidencia o remediación

– Keycloak TENIDO Identidad, roles, autenticación, MFA TENIDO Análisis de riesgos, operación de salvaguardia, evidencia o remediación – DefectDojo Silencio Encontrar el seguimiento de la ingesta y la remediación Silencio Velociraptor Silencio Visibilidad de endpoint y respuesta a incidentes Silencio Análisis de riesgos, operación de salvaguardia, evidencia o remediación Silencio TEN Open Policy Agent TENIDO POLÍTICA Como código TENIDO Análisis de riesgos, operación de salvaguardia, evidencia o remediación TENIDO

15.1 Matriz de verificación de la herramienta a la adquisición

Silencio **Herramienta o recurso** Silencio ** Apoyo a la HIPAA ** Silencio ** tarea de verificación ** Silencioso para retener ** Limitación importante ** Silencio

----- TEN CISO Assistant TEN 164.308(a)(1), 164.316, proveedor y gobernanza de pruebas TENER Map EPHI riesgos para las salvaguardias, propietarios, evidencias, hallazgos y tratamiento TENIDO registro de riesgos, matriz de control, aprobaciones, pista de auditoría TENER Registros en los que entran los usuarios; no prueba que la evidencia de origen es completa o precisa TEN HHS/ONC SRA Tool TENIDO 164.308(a)(1)(ii) (A) risk analysis Use preguntas estructuradas para identificar posibles lagunas de alcance y control TEN Evaluación completa, soporte de pruebas, acciones de tratamiento TEN A asistencia inicial; no garantiza un análisis preciso y minucioso de los riesgos institucionales TEN Silencio osquery Silencio 164.308(a)(1), 164.310(d), 164.312(a) y (d) Silencio Query endpoint users, software, cifrado, servicios, y dispositivo state – Query, lista de hosts, timestamps, resultados completos, decisión de revisor tención La cobertura depende de los puntos finales instalados y de presentación de informes y tablas del sistema operativo Silencio Keycloak Silencio 164.308(a)(3)–(4), 164.312(a) y (d) Silencio Prueba identidad única, roles, menos privilegios, MFA, acceso de emergencia y eliminación Silenciosos Configuración exportación, usuario y población de papel, resultados de prueba, aprobaciones Silencio Sólo verifica sistemas usando esa plataforma de identidad; autorización de aguas abajo puede diferir TEN i) i) ii) d), 164,308 a) 6), 164,312 b) Recopilación de registros de pruebas, generación de alerta, integridad de archivos, revisión, investigación y escalada ANTERI inventario, reglas, alerta, ticket de revisión, respuesta y cierre Una alerta sin un examen humano documentado y la respuesta no prueba que la salvaguardia opera TEN TEN OpenSCAP TEN 164.308(a)(8), 164.312(a), 164.312(c) TEN Comparar los hosts aprobados de Linux con una corrección de base de seguridad seleccionada y retest de retest ANTERI Perfil, versión de contenido, alcance de host, informe HTML/ARF, excepción, rescane TENIDOS Baseline no es el mismo que el cumplimiento de HIPAA y puede afectar las aplicaciones TEN Silencio Greenbone Silencio 164.308(a)(1), 164.308(a)(8) Silencio Medir cobertura de vulnerabilidad autenticada, validar hallazgos, plazos de pista, y recan Silencio Lista de objetivos, versión de alimentación y escáner, ajustes, informe, entradas, rescane durable No puede encontrar todas las debilidades; alcance, credenciales, falsos positivos y sistemas frágiles importa Silencio Trivy Silencio 164.308(a)(1), 164.312(c), software y riesgo en la nube Silencio Escanear código marcado, imágenes, dependencias, secretos y configuración de infraestructura TEN Target digest, base de datos y versión de herramientas,

ajustes, resultado, ticket, retest Tened Los resultados pueden contener secretos y pueden perderse los riesgos de funcionamiento, empresa-lógica y despliegue Tened OWASP ZAP Tened 164.308(a)(8), 164.312(c) y (e) Tened Revisión pasivamente y, cuando está autorizado, prueba activamente un laboratorio o aplicación web aprobada Tened Alcance escrito, versión, ajustes, hallazgos, validación, corrección, retest Tened Los escaneos activos pueden cambiar datos o interrumpir los sistemas de cuidado; la automatización no es una prueba de penetración completa Silencio DefectDojo Silencio 164.308(a)(1), 164.308(a)(6), corrective-action evidence Silencio Import findings, deduplicar, asigne, track risk decisions, retest, and close Silencio Encontrar historia, propietario, fecha de vencimiento, evidencia, aceptación de riesgo, cierre verificado tención El estado de flujo de trabajo no demuestra una solución; el cierre debe ser respaldado por una prueba independiente Silencio Velociraptor Silencio 164.308(a)(6), 164.312(b) Silencio Recopila los artefactos de punta aprobados durante una investigación aislada y cadena de documentos de custodia Silencio Solicitud de colección, resultados, notas de analista, registro de preservación Silencioso La colección poderosa puede exponer PHI o interrumpir los puntos finales; utilizar la autorización estricta y minimización Silencio Tened Open Policy Agent Tened 164.308(a)(1), 164.312(a) y (c) Silencio Test policy-as-code rules for required ownership, classification, encryption, or deployment conditions Tened Versión de política, tests, permitidos y negados insumos, decisión de tuberías, aprobación Las reglas de Tención sólo cubren condiciones codificadas; mala lógica o falta de integración crea falsa confianza

15.2 Cómo validar una herramienta antes de confiar en ella

- Aprobar el propósito, propietario, sistemas, límites ePHI, datos recogidos, alojamiento, acceso de soporte y retención.
- Verificar la fuente oficial de software, versión, dependencias, integridad de liberación, proceso de actualización y configuración segura.
- Crear una condición de prueba conocida y confirmar que la herramienta detecta o bloquea como se esperaba.
- Crear una condición permitida conocida y confirmar la herramienta no crea un fracaso innecesario.
- Compare la población de activos o agentes de la herramienta con un inventario independiente e investigue la cobertura perdida.
- Restringir el acceso administrativo, los cambios de registro, proteger las credenciales y probar la copia de seguridad o la recuperación de la propia herramienta.
- Definir los procedimientos de examen humano, escalada, excepción, corrección y reprobación.
- Revalidar después de importantes actualizaciones, cambios de configuración, nuevas integraciones o fallos de control de materiales.

15.3 Paquete de evidencia de herramientas

- Autorización escrita y alcance aprobado

- Nota de arquitectura y flujo de datos
- Herramientas, reglas, alimentación, bases de datos y versiones de contenido
- Autorizaciones de configuración y venta de servicios
- Activo completo, agente, población objetivo o repositorio
- Resultados brutos y resumidos
- Identidad, fecha, decisión y escalada del revisor
- Encontrar entradas, acciones correctivas, aceptación de riesgos y fechas debidas
- Prueba de revocación y cierre
- Limitaciones conocidas y áreas no comprobadas

“Un informe no es prueba, autorización, validación, remediación y retesting crear la cadena de evidencia” (No es una prueba única).

Gráfico 7 De la producción de herramientas a la evidencia de cumplimiento

15.4 CISO Assistant

GRC, riesgos, controles, evidencia.

Documentación y configuración oficiales Abra la guía oficial de asistentes CISO(<https://intuitem.gitbook.io/ciso-assistant>)

Quick start

Crear una organización de salud ficticia, añadir un riesgo de ePHI, mapear una salvaguardia de reglas de seguridad, asignar un propietario y adjuntar evidencias sanitarias.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.5 Wazuh

SIEM, monitoreo de puntos finales, integridad de archivos.

Documentación y configuración oficiales Abra la guía oficial Wazuh realizada/u título] (<https://documentation.wazuh.com/current/quickstart.html>)

Quick start

Conectar un punto final de laboratorio, crear un evento inofensivo, revisar la alerta y guardar el evento, la decisión del revisor y el seguimiento.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.6 OpenSCAP

Evaluación de configuración de Linux.

Característica y configuración: [ejecutado]Abre la guía oficial OpenSCAP realizada/u contacto](<https://www.open-scap.org/getting-started/>)

Quick start

Evaluar un host Linux de laboratorio contra un perfil adecuado, exportar el informe, fijar un ajuste aprobado y comparar resultados.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.7 Greenbone Community Edition

Escaneo de vulnerabilidad.

Documentación y configuración oficiales: [Seguridad]Abre la guía oficial Greenbone Community Edition realizada/u contactos](<https://greenbone.github.io/docs/latest/>)

Quick start

Escanear sólo un objetivo de laboratorio aprobado, validar un hallazgo, corregirlo, cambiar y registrar el alcance, versión, resultado y revisor.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.8 osquery

Fin de inventario y consultas.

Documentación y configuración oficiales: [Seguridad]Abre la guía oficial del osquery realizada/u contacto](<https://osquery.readthedocs.io/en/stable/>)

Quick start

Query users, software, cifrado, o procesos en un endpoint de laboratorio y grabar la consulta, host, fecha, resultado y revisión.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.9 Trivy

Código, imagen, secreto y análisis de configuración.

Documentación y configuración oficiales Abra la guía oficial Trivy realizada/u título](<https://trivy.dev/latest/>)

Quick start

Escanear una imagen de laboratorio o un repositorio de pruebas, proteger el informe, validar un hallazgo, arreglarlo y volver a escanear.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.10 OWASP ZAP

Pruebas de aplicación web autorizadas.

Documentación y configuración oficiales Abra la guía oficial OWASP ZAP efectuada / u fiel](<https://www.zaproxy.org/getting-started/>)

Quick start

Proxy una aplicación de entrenamiento local, empezar con análisis pasivos, validar un resultado, y exportar el alcance y el informe.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.11 Keycloak

Identidad, roles, autenticación, MFA.

Característica y configuración: [ejecutado] Abre la guía oficial de Keycloak realizada/u contacto](<https://www.keycloak.org/guides>)

Quick start

Crear un ámbito de laboratorio, roles, usuarios y MFA; probar menos privilegios y configuración de exportación y revisar pruebas.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.12 DefectoDojo

Encontrar captación y seguimiento de remediación.

Característica y configuración: [ejecutado] Abre el defecto oficialDojo guía seleccionada/u contacto](<https://docs.defectdojo.com/>)

Quick start

Importar un análisis de laboratorio, validar y asignar un hallazgo, registrar la corrección, retestarlo y cerrarlo con evidencia.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.13 Velociraptor

Visibilidad del punto final y respuesta a incidentes.

Documentación y configuración oficiales Abra la guía oficial Velociraptor realizada/u título](<https://docs.velociraptor.app/>)

Quick start

Utilice un cliente de laboratorio aislado, recoger un artefacto aprobado inofensivo, revisar el resultado, y registrar el propósito, alcance y acceso.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.14 Open Policy Agent

Política como código.

Documentación y configuración oficiales Abra la guía oficial de Agentes de Política Abierta(<https://www.openpolicyagent.org/docs>)

Quick start

Escribir una regla de laboratorio que niega un recurso de ePHI sin un propietario o etiqueta de clasificación; probar los insumos permitidos y negados.

Evidencia para retener

Aprobación de registros, propósito, propietario, alcance, sistemas, clasificación de datos, versión de herramientas y contenidos, configuración, resultado completo, revisor, decisión, acción correctiva y retest. Protege los informes que contienen ePHI, credenciales, arquitectura, identidades o vulnerabilidades.

15.15 Recursos del gobierno libre

**** Herramienta de evaluación del riesgo de seguridad HHS/ONC:**** [traducido]Abre la página oficial de Herramienta SRA:

Este recurso público gratuito puede ayudar a las prácticas pequeñas y medianas a iniciar una evaluación estructurada del riesgo. No garantiza el cumplimiento y no sustituye un análisis completo de riesgos específico para la organización.

15.16 Lista de verificación de gobernanza de herramientas

- Usar datos ficticios o adecuadamente desidentificados en el entrenamiento.
- Obtenga autorización escrita antes de escanear, monitorear, recoger o probar.
- Aprobar propietario, alcance, alojamiento, acceso, manejo de datos, retención y ubicación de soporte.
- Verificar fuentes de software, liberaciones, dependencias, firmas y procedimientos de actualización.

- Utilizar menos privilegios y proteger las credenciales e informes de servicio.
- Defina quién valida los resultados, resuelve los hallazgos, aprueba excepciones y retests.
- No suba PHI o ePHI a ningún servicio externo sin revisión legal, de privacidad, seguridad, contrato y de flujo de datos.

16. Fictional Healthcare Laboratory and Portfolio

Un entorno de práctica completo utilizando sólo información sintética.

Harbor Light Health es una clínica ambulatoria ficticia y administrador del plan de salud. Utiliza un EHR, sistema de facturación, correo electrónico en la nube, portal de pacientes, dispositivos médicos, soporte remoto y varios asociados comerciales. Cada persona, registro, dirección, reclamación, diagnóstico e identificador en el laboratorio se inventa.

Project 1 — Scope and roles

Funciones de identificación cubierta, asociados de negocios, límites híbridos, PHI, ePHI, sistemas y flujos de datos.

Proyecto 2 - Análisis de riesgos

Crear un registro de inventario, amenazas y vulnerabilidad del sistema, método de riesgo, hallazgos y plan de tratamiento.

Proyecto 3 - Salvaguardias de seguridad

Construir una matriz de reglas de seguridad con los propietarios, opciones de implementación, pruebas, excepciones y retests.

Project 4 - Privacy rights

Acceso ficticio completo, enmiendas, comunicaciones confidenciales y solicitudes de contabilidad.

Proyecto 5 - Breach

Evaluar una exportación de facturación mal dirigida utilizando los cuatro factores y preparar decisiones de notificación.

Project 6 — Vendor

Revise una nube de ficción BA, términos de contrato, subprocesadores, evidencia de seguridad, derechos de incidencia y plan de salida.

Project 7 — Tools

Use tres herramientas Capítulo 15 en un laboratorio y alcance de documentos aislados, limitaciones, hallazgos, corrección y retest.

16.1 Portfolio ethics

Nunca publique información de paciente real, miembro, empleado, proveedor o reclamación.

Etiqueta cada archivo como trabajo de entrenamiento ficticio.

No copie el análisis confidencial de riesgos de una empresa, BAA, incidente o arquitectura.

Eliminar nombres de usuario, caminos, nombres de host, fichas, claves, direcciones IP y metadatos ocultos antes de la publicación.

Explicar suposiciones y donde se requiere revisión legal, de privacidad, clínica o de seguridad.

17. Plan de aprendizaje de 30 días

Un mes realista de lectura, práctica, trabajo de cartera y preparación de entrevistas.

Silencio **Week** Silencio** Silencio————— — Semana 1 TENIDO Alcance, roles, PHI/ePHI, Privacy Rule TENIDO Scope memo, mapa de datos, ejemplos de uso/disclosure Silencioso Semana 2 Silencioso Seguridad Regla y análisis de riesgos Silencioso Semana 3 Silencioso Derechos, violación, proveedores, Parte 2 Silencioso archivo Derechos, evaluación de la violación, revisión de los proveedores Silencio Semana 4 Silencio Herramientas, portafolio, entrevista Silencio Portafolio y respuestas prácticas

17.1 hábitos diarios

Lea una sección HHS actual, eCFR o NIST.

Explique un requisito en sus propias palabras.

Crear un elemento de evidencia ficticia.

Revise para la integridad, sensibilidad y fechas.

Añadir una corrección o lección a la cartera.

18. Preparación de entrevistas

Preguntas y respuestas cortas para analistas y administradores.

¿Quién debe cumplir con HIPAA?

Entidades cubiertas, socios comerciales y ciertos arreglos conexos. Las entidades cubiertas incluyen planes de salud, centros de intercambio y proveedores calificadores que realizan transacciones electrónicas cubiertas.

¿Qué es PHI?

Información de salud individualizada mantenida o transmitida por una entidad o empresa asociada, con sujeción a exclusiones reglamentarias.

PHI versus ePHI?

El PHI puede ser electrónico, papel o oral. ePHI es PHI mantenido o transmitido electrónicamente y es el foco de la Regla de Seguridad.

¿Qué es mínimo necesario?

Cuando sea aplicable, limite el uso, la divulgación y las solicitudes de información sobre el uso razonablemente necesario para el propósito.

¿Qué es un análisis de riesgo HIPAA?

Una evaluación precisa y exhaustiva de los posibles riesgos y vulnerabilidades a la confidencialidad, integridad y disponibilidad de todo el ePHI mantenido por la entidad regulada.

¿Significa opcional?

No. Evaluar la especificación y aplicarla si es razonable y apropiado. De lo contrario, documente la decisión y utilice una alternativa equivalente cuando sea razonable y apropiada.

¿Cuál es el estándar de la brecha?

Se presume una violación de un uso o revelación inadmisibles a menos que una evaluación documentada de cuatro factores muestre una baja probabilidad de que la PHI estuviera comprometida o se aplique una excepción.

¿Cómo apoyan el cumplimiento los socios de negocios?

Siguen las obligaciones de BAAs y las obligaciones HIPAA aplicables, protegen el ePHI, administran subcontratistas, informan sobre incidentes e infracciones, apoyan derechos y devuelven o destruyen PHI según sea necesario.

¿Cómo demuestras que funciona una salvaguardia?

Use pruebas completas, fechadas que conecten el alcance, el riesgo, el requisito, la aplicación, el propietario, el examen, la excepción, la acción correctiva y la repetición.

18.1 Respuesta del administrador de 60 segundos

- Respuesta de la perspectiva:** Trato a HIPAA como un programa operativo, no como una carpeta de políticas. Definir funciones reguladas y alcance de la ePHI, realizar análisis de riesgos continuos, aplicar salvaguardias administrativas, físicas y técnicas, gestionar el acceso y los proveedores, hacer que los derechos de privacidad funcionen, evaluar los incidentes con prontitud y exigir pruebas fiables. La administración posee recursos y decisiones de riesgo mientras que los equipos de privacidad, legales, de seguridad, clínicos y de cumplimiento proporcionan una revisión especializada.
Respuesta

19. Plantillas y listas de verificación

- Estructuras prácticas para un sistema de organización aprobado*.

19.1 ePHI inventory fields

Sistema, aplicación, dispositivo, interfaz, repositorio, medios o servicio

Empresa y propietario técnico

Entidad cubierta o función asociada comercial

Tipos de ePHI, volumen, personas, propósito y crítica

Usuarios, acceso privilegiado y autenticación

Ubicación, alojamiento, soporte remoto y flujo de datos

Encriptación, registro, copia de seguridad, recuperación, retención y eliminación

Vendor, BAA, subcontratistas y contacto con incidentes

Última revisión, activación del cambio y próxima revisión

19.2 Campos de registro de riesgos

Alcance de activos y ePHI

Amenaza, vulnerabilidad y salvaguardia existente

La probabilidad y el impacto

Evaluación y método del riesgo

Tratamiento, propietario, recursos y fecha

Residual risk and acceptance authority

Excepcional expiración

Validación y reprobación pruebas

19.3 Breach fact sheet

Silencio **Field** Silencio **Información requerida** Silencio. Silencio Descubrimiento Silencio
Quien lo descubrió, cuándo, y cuando la entidad se hizo consciente Silencio Qué pasó, sistemas,
cuentas, ubicación, contención TEN PHI TENIDO Naturaleza, sensibilidad, identificadores,
personas, cantidad, probabilidad de reidentificación ANTE Recipiente de la vida Quienes lo
recibieron o accedieron y sus obligaciones Silencioso Adquisición Silencio Si PHI fue adquirido o
visto en realidad TENIDA Mitigation TEN Retrieval, deletion, assurances, account actions,
monitoring TEN TENCIÓN TENIDA Excepción o análisis de baja probabilidad, avisos,
aprobadores TEN – Acción permanente Corrección, sanciones, capacitación, pruebas, lecciones

19.4 BAA checklist

Funciones y servicios correctos

Uso/desconexión permitido y requerido definido

Salvaguardias y obligaciones en materia de normas de seguridad

Tiempo y contenido de presentación de informes sobre incidentes e infracciones

Flujo subcontratista

Derechos y apoyo contable

HHS access

Retorno/destrucción y manejo de infeasibilidad

Derechos de rescisión

Contactos, ubicaciones, cambios y cadencia de revisión

19.5 Manager pre-audit checklist

Alcance y funciones de organización aprobadas

Mapa completo de inventario ePHI y flujo de datos

Análisis de riesgo preciso y exhaustivo actual

Tratamiento de riesgo con pruebas y pruebas

Decisiones de aplicación de la salvaguardia documentadas

Acceso, examen de actividad, capacitación, copia de seguridad y muestras de incidentes completas

Población y seguimiento completos

Derechos de privacidad y evidencia de divulgación completa

Breach log and HHS reports reconciled

Se mantiene la documentación actual y necesaria durante seis años

20. Glosario

Definiciones en inglés de HIPAA importantes y términos de privacidad en salud.

**** Especificación de la aplicación adicional**** Una especificación de la Regla de Seguridad que debe evaluarse y aplicarse cuando sea razonable y apropiada, o sustituirse por una alternativa equivalente documentada cuando proceda.

Autorización. Un permiso por escrito que reúne los elementos y declaraciones requeridos de la Regla de Privacidad.

Breach. Una adquisición, acceso, uso o divulgación inadmisibles que comprometa la seguridad del PHI o la privacidad, con sujeción a la presunción de la norma, la evaluación del riesgo y las excepciones.

Asociado de negocios. A person or organization performing certain functions or services involving PHI for a covered entity.

Ente civil. Un plan de salud, un centro de salud o un proveedor de atención médica calificado bajo HIPAA.

Diseño de registros. Registros mantenidos por o para una entidad cubierta que determine o documente determinados derechos de salud, reclamaciones, pagos o información de gestión de casos y de apoyo.

ePHI. La información de salud protegida se mantiene o transmite electrónicamente.

**** Operaciones de atención de salud.**** Actividades operacionales definidas como la calidad, la competencia, los límites de escritura, la auditoría, la planificación y las funciones de gestión.

HITECH Act A federal law that expanded health-information technology, breach, business associate, and HIPAA enforcement provisions.

Minimum necessary. Un requisito, cuando sea aplicable, para limitar el uso, la divulgación y las solicitudes de PHI a lo que es razonablemente necesario.

Parte 2. Las normas federales de confidencialidad para los registros de programas de trastorno de uso de sustancias asistidas federalmente bajo 42 CFR Parte 2.

PHI. Datos de salud individualizados protegidos por HIPAA cuando sean mantenidos o transmitidos por una entidad cubierta o asociada comercial, sujetos a exclusiones.

Regla de Privación****** The HIPAA standards for PHI use, disclosure, individual rights, and privacy administration.

Especificación necesaria de la aplicación. Una especificación de la aplicación de las normas de seguridad que debe aplicarse.

Análisis de ruido. Una evaluación precisa y exhaustiva de los riesgos y vulnerabilidades a todos los ePHI.

**** Gestión de riesgos.**** Medidas de seguridad que reducen los riesgos y vulnerabilidades identificados a un nivel razonable y adecuado.

Regla de seguridad. Las normas HIPAA que protegen el ePHI mediante salvaguardias administrativas, físicas y técnicas.

**** Operaciones de tratamiento, pago y atención de la salud.**** Categorías básicas para uso permitido de PHI y divulgación bajo la regla.

**** PHI no garantizado.**** El PHI no se ha vuelto inutilizable, inleable o indescriptible a través de la tecnología o metodología especificada por el HHS.

21. Índice de asunto

Una guía alfabética para los principales temas. Referencias apuntan a secciones para que el índice siga siendo útil después de la edición.

- Tema* Tema *Las secciones** Tema Silencio
----- TENIDO Acceder a la
derecha Silencio 4, 12.2, 19 TENIDO Aviso sobre las prácticas de privacidad Silencio
Addressable Silencio 5.2, 20 Silencio Herramientas de código abierto Silencio 15 Silencio
Silenciosos salvaguardias administrativas Silencioso 6, 12.1 Silencioso Autorización
Silencio 3.3, 12.2 Silencio Silencioso en la vida 8, 12,3, 19.3 Silencioso socio de negocios
Silencioso 2.2, 9, 19.4 Silencioso Privacidad Regla 3-4, 12.2 Silencio Silencio
Deidentificación Silencio 2.4, 3.5 Silencio Salud reproductiva TENIDO EPHI TENIDO 2.3,
5-7 TENIDO Análisis del riesgo ANTE 5.3, 6, 12.1 TENIDO Silenciosos en la práctica 11,
12.4 Silenciosos TENIDO HIPAA Security Rule NPRM TEN 1.3, 11.4 TENIDO LA LEY DEL
ESTADO Silencio 10.2, 11.3 Silencio Derechos individuales Silencio 4 Silencio Silencioso
analista junior Silencio Mínimo necesario Silencio 3.4, 12.2 Silencioso entrenamiento de
fuerza de trabajo

22. Referencias oficiales y estudio ulterior

Current government law, guidance, tools, and official project documentation used for verification.

[Se indica] (<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-160>)

[Se indica] (<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164>)

[Seguido] (HIPAA para profesionales)

Norma de privacidad

[Se indica] (<https://www.hhs.gov/hipaa/for-professionals/security/index.html>)

[Se indica] (<https://www.hhs.gov/hipaa/for-professionals/breach-notification/index.html>)

[Se indica] (<https://www.hhs.gov/hipaa/for-professionals/security/guidance/guidance-risk-analysis/index.html>)

[] (<https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/audit/protocol/index.html>)

[Se indica] (<https://www.hhs.gov/hipaa/for-professionals/covered-entities/sample-business-associate-agreement-provisions/index.html>)

[indicau]HHS — 42 CFR Segunda parte:

[Se indica] (<https://www.hhs.gov/hipaa/for-professionals/special-topics/reproductive-health/index.html>)

[indica] HHS — Regla de Seguridad NPRM hecha/u título] (<https://www.hhs.gov/hipaa/for-professionals/security/hipaa-security-rule-nprm/index.html>)

[] (<https://csrc.nist.gov/pubs/sp/800/66/r2/final> SP 800-66 Rev. 2 operacionales/u título] (<https://csrc.nist.gov/pubs/sp/800/66/r2/final>)

[] (<https://www.healthit.gov/topic/privacy-security-and-hipaa/security-risk-assessment-tool>)

[] (<https://intuitem.gitbook.io/ciso-assistant>)

Se indica

[] (<https://www.open-scap.org/getting-started/>)

Se indica

Se indica

Se indica

Se indica

Se indica

Se indica

Se indica

[] (<https://www.openpolicyagent.org/docs>)

Silencio **Recuerdo final:** Reglamentos, decisiones judiciales, orientación, cuantías de la pena, tecnología y cambios de hechos. Verifique las fuentes actuales de eCFR, HHS y NIST, ley estatal, estado de la Parte 2 y asesoramiento legal calificado antes de actuar en un asunto real. ←

Respuesta